

# Email Security Posture Assessment

broken.example

22

F

High risk

|                |                                  |
|----------------|----------------------------------|
| Scan date      | 18 September 2026, 20:43 UTC     |
| Scan ID        | c69c738bf866                     |
| Checks run     | 7                                |
| Findings       | 4 failing, 6 warnings, 1 passing |
| Narrative      | Rule-based (built-in)            |
| Engine version | 1.0.0                            |

## Executive summary

broken.example scores 22/100 (F) — high risk. The assessment found 3 high-severity and 7 lower-severity issues. The most consequential — DMARC policy is `p=none` (monitoring only) — matters because: `p=none` asks receivers to report on failures but to deliver the mail anyway. A message forged as `@broken.example` that fails both SPF and DKIM still lands in the recipient's inbox, so the domain remains usable for phishing and invoice-fraud campaigns. Monitoring mode is the correct first step, but it is not enforcement. The practical consequence is that broken.example is currently spoofable: an attacker can put your domain in the From: header of a phishing or invoice-fraud message and receiving servers have no instruction to stop it.

### What an attacker could do with this

- Forged mail is reported to you but still delivered. A spoofing campaign runs to completion; you find out afterwards from the aggregate reports, which is useful for forensics and useless for prevention.
- Unlisted senders get a neutral result, which receivers weigh the same as having no policy at all.
- Any host inside the authorised range passes SPF for your domain. On shared hosting or a cloud provider's range, that includes machines you do not control.
- Nobody receives the daily reports naming the hosts that send as your domain, so an ongoing spoofing campaign produces no signal your team can act on.
- Receivers are told to treat signature failures as if the message were unsigned, so the signature provides no enforcement benefit.

Narrative generated by the built-in rule-based writer. Reason: LLM disabled for this scan

## Score by category

| Category           | Earned | Available | Result |
|--------------------|--------|-----------|--------|
| Authentication     | 9.0    | 65.0      | 14%    |
| Policy & Reporting | 7.6    | 10.0      | 76%    |

Excluded from scoring because the check could not complete: transport. These are neither counted as passing nor as failing — the score is calculated over the checks that returned a conclusive result.

## Findings

### [HIGH] SPF record ends in `?all` (neutral)

A neutral result carries no more weight than having no SPF record. Receivers are explicitly told to treat the sender as unverified.

```
record = v=spf1 ip4:10.0.0.0/8 ptr include:relay.example ?all  
qualifier = ?
```

**Fix:** Move to `~all` while monitoring, then to `-all`.

Reference: RFC 7208 §5.1

### [HIGH] SPF authorises an extremely large IP range (ip4:10.0.0.0/8)

10.0.0.0/8 authorises at least 16 million addresses as legitimate senders. An attacker with a host anywhere in that range passes SPF for this domain.

```
term = ip4:10.0.0.0/8  
prefix_length = 8
```

**Fix:** Narrow the range to the addresses your mail servers actually use.

Reference: RFC 7208 §5.6

### [HIGH] DMARC policy is `p=none` (monitoring only)

`p=none` asks receivers to report on failures but to deliver the mail anyway. A message forged as @broken.example that fails both SPF and DKIM still lands in the recipient's inbox, so the domain remains usable for phishing and invoice-fraud campaigns. Monitoring mode is the correct first step, but it is not enforcement.

```
record = v=DMARC1; p=none; sp=none; pct=40  
p = none
```

**Fix:** After reviewing aggregate reports for legitimate senders, move to p=quarantine, then p=reject.

Reference: RFC 7489 §6.3

### [MEDIUM] SPF uses the deprecated `ptr` mechanism

`ptr` is deprecated: it is slow, imposes load on reverse-DNS infrastructure, and some receivers skip it entirely, producing inconsistent results for the same message.

```
term = ptr
```

**Fix:** Replace `ptr` with explicit ip4/ip6 or include terms.

Reference: RFC 7208 §5.5

### [MEDIUM] No DMARC aggregate reporting address (`rua=`)

Without rua=, no one receives the daily reports showing which hosts are sending as this domain and whether they pass authentication. Spoofing campaigns and misconfigured legitimate senders both go unnoticed, and there is no data on which to base a move to p=reject.

```
record = v=DMARC1; p=none; sp=none; pct=40
```

**Fix:** Add rua=mailto:dmarc-reports@yourdomain (or a reporting service).

Reference: RFC 7489 §7.1

### **[MEDIUM] DKIM selector `google` is in testing mode (`t=y`)**

`t=y` tells receivers to treat verification failures as if the message were unsigned. Signatures from this selector therefore provide no enforcement benefit — including for DMARC alignment.

```
selector = google
record = v=DKIM1; k=rsa; t=y;
p=MIGfMA0GCSqGSIb3DQEBAQUAA4GNADCBiQKBgQCWxmH0v7u2ZZE+EwVs0wkr6jGvTiX3xJQ8c7fNdqUcQv3zGgl...
```

**Fix:** Remove t=y once signing is confirmed working.

Reference: RFC 6376 §3.6.1

### **[MEDIUM] DKIM key at `google` is 1024-bit RSA**

RFC 8301 sets 1024 bits as the minimum receivers must accept and 2048 as the recommended size. A 1024-bit key is within reach of a well-resourced attacker and should be rotated.

```
selector = google
key_bits = 1024
algorithm = rsa
```

**Fix:** Rotate to a 2048-bit RSA key at your mail provider.

Reference: RFC 8301 §3.2

### **[MEDIUM] MTA-STS is not configured**

No MTA-STS record exists at `_mta-sts.broken.example`. SMTP's opportunistic TLS can be stripped by an on-path attacker simply by removing the STARTTLS advertisement from the server greeting — the sending server then delivers the message in cleartext and nothing alerts either party. MTA-STS is the mechanism that makes TLS mandatory and detectable for inbound mail.

```
queried = _mta-sts.broken.example
records_found = 0
```

**Fix:** Publish TXT "v=STSV1; id=<timestamp>" at `_mta-sts.broken.example` and host a policy file at `https://mta-sts.broken.example/.well-known/mta-sts.txt`, starting in mode: testing before moving to mode: enforce.

Reference: RFC 8461 §3

### **[LOW] SPF is close to the DNS-lookup limit (9/10)**

9 of the 10 permitted lookups are in use. Adding one more mail provider — or a provider expanding their own include — would break SPF evaluation for the whole domain.

```
lookups = 9
limit = 10
```

**Fix:** Reduce the number of include: terms before adding senders.

Reference: RFC 7208 §4.6.4

## [LOW] TLS-RPT is not configured

No TLS-RPT record at `_smtp._tls.broken.example`. Sending servers have nowhere to report failed TLS negotiations, so a downgrade attack or an expired certificate on your MX would produce no signal to your team — you would learn about it from users, if at all.

```
queried = _smtp._tls.broken.example
records_found = 0
```

**Fix:** Publish TXT "`v=TLSRPTv1; rua=mailto:tls-reports@broken.example`" at `_smtp._tls.broken.example`.

Reference: RFC 8460 §3

## Controls verified as correctly configured

— DMARC alignment: `adkim=r, aspf=r`

## Not assessed

— BIMi is not configured: No BIMi record found. BIMi displays a verified brand logo beside authenticated mail; it is optional, requires DMARC at enforcement first, and its absence is not a security weakness.

— TLS probing was disabled for this scan: 1 MX host(s) were discovered but not contacted.

## Remediation plan

Ordered by risk reduced, not by effort required.

| #  | Action                                                                                                                                                                                                                                      | Severity |
|----|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------|
| 1  | After reviewing aggregate reports for legitimate senders, move to <code>p=quarantine</code> , then <code>p=reject</code> .                                                                                                                  | high     |
| 2  | Move to <code>`~all`</code> while monitoring, then to <code>`-all`</code> .                                                                                                                                                                 | high     |
| 3  | Narrow the range to the addresses your mail servers actually use.                                                                                                                                                                           | high     |
| 4  | Add <code>rua=mailto:dmARC-reports@yourdomain</code> (or a reporting service).                                                                                                                                                              | medium   |
| 5  | Replace <code>`ptr`</code> with explicit <code>ip4/ip6</code> or include terms.                                                                                                                                                             | medium   |
| 6  | Remove <code>t=y</code> once signing is confirmed working.                                                                                                                                                                                  | medium   |
| 7  | Rotate to a 2048-bit RSA key at your mail provider.                                                                                                                                                                                         | medium   |
| 8  | Publish TXT " <code>v=STSV1; id=</code> " at <code>_mta-sts.broken.example</code> and host a policy file at <code>https://mta-sts.broken.example/.well-known/mta-sts.txt</code> , starting in mode: testing before moving to mode: enforce. | medium   |
| 9  | Reduce the number of include: terms before adding senders.                                                                                                                                                                                  | low      |
| 10 | Publish TXT " <code>v=TLSRPTv1; rua=mailto:tls-reports@broken.example</code> " at <code>_smtp._tls.broken.example</code> .                                                                                                                  | low      |

## Method and scope

This assessment is passive and read-only. It consists of public DNS lookups (SPF, DKIM, DMARC, MTA-STS, TLS-RPT and BIMi records), an HTTPS GET of the domain's published MTA-STS policy file, and SMTP connections to the mail hosts the domain itself advertises in its MX records, used to observe the server's own STARTTLS advertisement and complete a TLS handshake.

The assessment does not send test phishing messages, does not attempt authentication or authentication bypass, does not relay or deliver mail, does not access mailbox contents, and does not attempt to exploit any weakness it identifies. No credentials are used and no data is submitted to the target. Connections are closed with QUIT and are rate-limited per domain.

Scoring assigns each check a share of 100 points weighted by the attacker leverage a failure grants (dmarc 30, transport 25, spf 20, dkim 15, mta\_sts 7, tls\_rpt 3). Each finding removes a fraction of its check's points by severity: critical 100%, high 60%, medium 30%, low 10%. A check that could not complete is removed from the denominator rather than counted as a failure, so a network restriction on the scanner is never reported as a weakness in the assessed domain.

The narrative section is generated from the findings above and is constrained to them: it cannot introduce a finding the engine did not produce, and any generated text that references an unknown finding or states a score other than the computed one is rejected and replaced by the built-in rule-based writer.

Generated 18 September 2026 at 20:44 · Scan ID c69c738bf866